Zero Trust Security with OCI

OUT1015 Practice 2: Keep the Private Application Private

Table of Contents

Zero Trust Security with OCI **1**
Introduction 3
About This Workshop 3
Architecture 3
Get Started 5
Prerequisites 5
Sign In to the Lab Tenancy 5
Sign In and Check Your Region 5
Find Your Participant Number 5
How to Read This Guide 6
Practice 2: Keep the Private Application Private 7
Introduction 7
Objectives 7
Prerequisites 7
Practice 2-1: Set Up Your Values in Cloud Shell 7
Practice 2-2: Use the Customer Path 8
Practice 2-3: Find the Rules That Apply to the Private Subnet 8
Practice 2-4: Check the Application's Network Security Group 9
Practice 2-5: Maintain the Application Through Bastion 10
Practice 2-6: Reproduce the Incident 13
Practice 2-7: Remove the Broad Rule 14
Practice 2-8: End the Administrator Session 15
Checkpoint: What You Proved 15
Learn More 16
Need Help? 17
Clean Up 18
Check for Leftover Lab Changes 18
Acknowledgements 19

Copyright © 2026, Oracle and/or its affiliates.

Introduction

About This Workshop

Summit Retail is moving its online store to Oracle Cloud Infrastructure (OCI). Asha leads cloud security for the move. Over one day she handles a series of security incidents, and each one leads to a Zero Trust decision: grant access on purpose, verify every request, and assume that one control can fail.

You watch some incidents as instructor demonstrations, and you fix three of them yourself. Each practice starts with what Asha sees, shows you the part of the architecture involved, and then gives you short tasks. After each task you compare your result with the expected result.

This guide covers **Practice 2: Keep the Private Application Private**. The workshop has four practices, each in its own guide. Do Practice 0 first: it builds the environment that the other practices use. Practices 1, 2, and 3 each need only Practice 0, so you can do them in any order.

Practice	What you do	Time
Practice 0	Prepare your Summit Retail environment (Cloud Shell, Terraform)	20 minutes
Practice 1	Get the password out of the code (OCI Vault, instance principals)	25 minutes
Practice 2	Keep the private application private (Security Lists, NSGs, Bastion)	30 minutes
Practice 3	Inspect the requests, not only the port (Web Application Firewall)	35 minutes

Architecture

Practice 0 builds everything in the diagram except the vault, which the lab team prepared, and the WAF policy, which you add in Practice 3. The badges show where each practice works.

Copyright © 2026, Oracle and/or its affiliates.

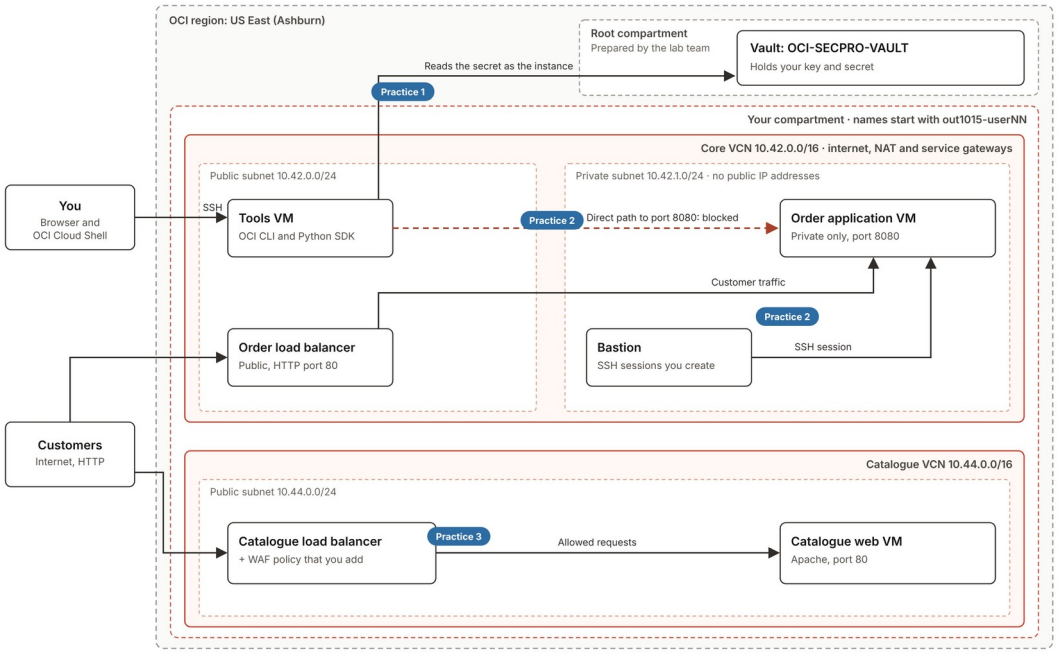


Figure 1: The Summit Retail lab environment in your compartment

The core VCN holds the order system. Customers reach the order application only through the public load balancer. The application server has no public IP address, and you reach it for administration only through OCI Bastion. The Tools VM plays the role of an administrator's or another team's machine inside the same VCN. A second VCN holds the product catalogue, which you protect with WAF.

Copyright © 2026, Oracle and/or its affiliates.

Get Started

Prerequisites

- The lab account details from your instructor: the sign-in URL or tenancy name, your username and password, and your assigned compartment.
- A laptop with a current web browser. You need no other software, because every command runs in OCI Cloud Shell.

Sign In to the Lab Tenancy

Your instructor gives you a lab account in a shared tenancy. Every participant works in their own compartment, so your resources never mix with anyone else's.

Sign In and Check Your Region

1. Open the sign-in URL from your lab details, or go to `https://cloud.oracle.com` and enter the tenancy name.

2. Sign in with the username and password from your lab details. If you are asked to change the password, choose a new one and keep it for the rest of the day.

3. In the Console header, open the region selector and select **US East (Ashburn)**. Every practice uses this region.

4. From the navigation menu, select **Identity & Security**, and then click **Compartments**. Find your assigned compartment in the list, for example `98507690-C07`.

   > **Expected result**
   >
   > You are signed in, the region is US East (Ashburn), and you can see your assigned compartment.

Find Your Participant Number

1. Look at your username. It ends with your participant number, for example `98507690-lab.user07`.

2. Write down the last part, `userNN`, for example `user07`. Everywhere this guide shows `userNN` or `NN`, use your own number.

Copyright © 2026, Oracle and/or its affiliates.

> **Note**
>
> Your compartment uses the same number: user07 works in compartment 98507690-C07. The Practice 0 package reads both from your username, and asks you to confirm them.

How to Read This Guide

You see	It means
A light box with a red left edge	Text that you enter or select in the OCI Console.
A dark box that starts with $	A command to run. The task tells you where: in Cloud Shell or on a VM. Do not type the $.
A gray box	Output that you should see. Details such as IDs, dates, and IP addresses differ for you.
Expected result	What to check before you move on.
`<value>`	A placeholder. Replace it with your own value, without the angle brackets.

> **Note**
>
> Console labels sometimes move between releases. If a button is not where the guide says, look for the same action in the **Actions** menu or under the three-dot icon.

Copyright © 2026, Oracle and/or its affiliates.

Practice 2: Keep the Private Application Private

Introduction

Summit Retail's order application runs on a VM with no public IP address. Three groups need something from it. Customers use it through the public load balancer. Asha maintains it as an administrator. Every other machine should have no direct path to it at all.

Last night a colleague needed a monitoring script on the Tools VM to reach the application, so they added a quick rule to the private subnet. This morning Asha finds that any machine in the VCN can reach the application directly. In this practice you look at each network control on its own, use the two intended paths, then reproduce the colleague's change and remove it.

Estimated time: 30 minutes.

Objectives

- Identify where a Security List applies and which resources belong to a network security group (NSG).
- Reach the private application as an administrator through an OCI Bastion session.
- Show that customers reach the application through the load balancer only.
- Reproduce the broad rule, see the unintended direct path, and remove the rule without breaking the customer path.

Prerequisites

- Practice 0 is complete, and you have your `tools_public_ip`, `app_private_ip`, and `order_url`.
- Cloud Shell is open, and you are in the `~/out1015-lab` folder.

Practice 2-1: Set Up Your Values in Cloud Shell

1. In Cloud Shell, store your values from Practice 0 in variables. Replace each placeholder with your own value; `ORDERS` is the whole `order_url`, starting with `http://`:

```
$ KEY=~/out1015-lab/.local/workshop_ssh
$ TOOLS=<tools_public_ip>
$ APP=<app_private_ip>
$ ORDERS=<order_url>
```

Copyright © 2026, Oracle and/or its affiliates.

> **Note**
>
> Cloud Shell forgets variables when it restarts. If a later command shows an empty address, set the four variables again.

Practice 2-2: Use the Customer Path

1. Open your `order_url` in a browser tab. The Summit Retail order application page shows **Service is running**.

2. Check the same path from Cloud Shell:

```
$ curl -sS $ORDERS/healthz
```

```
summit-order-app: ok
```

> **Expected result**
>
> Customers reach the application through the public load balancer. The application VM itself has no public IP address.

Practice 2-3: Find the Rules That Apply to the Private Subnet

A Security List belongs to a subnet. Its rules apply to every VNIC in that subnet.

1. From the navigation menu, select **Networking**, and then click **Virtual cloud networks**. Next to **Applied filters**, select your assigned compartment.

2. Click `out1015-userNN-core-vcn`. Click the **Subnets** tab, and then click `out1015-userNN-core_private`.

3. Click the **Security** tab. In the **Security Lists** section, click `out1015-userNN-core_private-security-list`.

4. Click the **Security rules** tab, and look at both sections:

Section	What you see	Why
Ingress Rules	No rules	Nothing enters the private subnet because of this list.
Egress Rules	TCP port 22 to the application's IP address (`/32`)	Lets the Bastion endpoint in this subnet open SSH sessions to the application.

Copyright © 2026, Oracle and/or its affiliates.

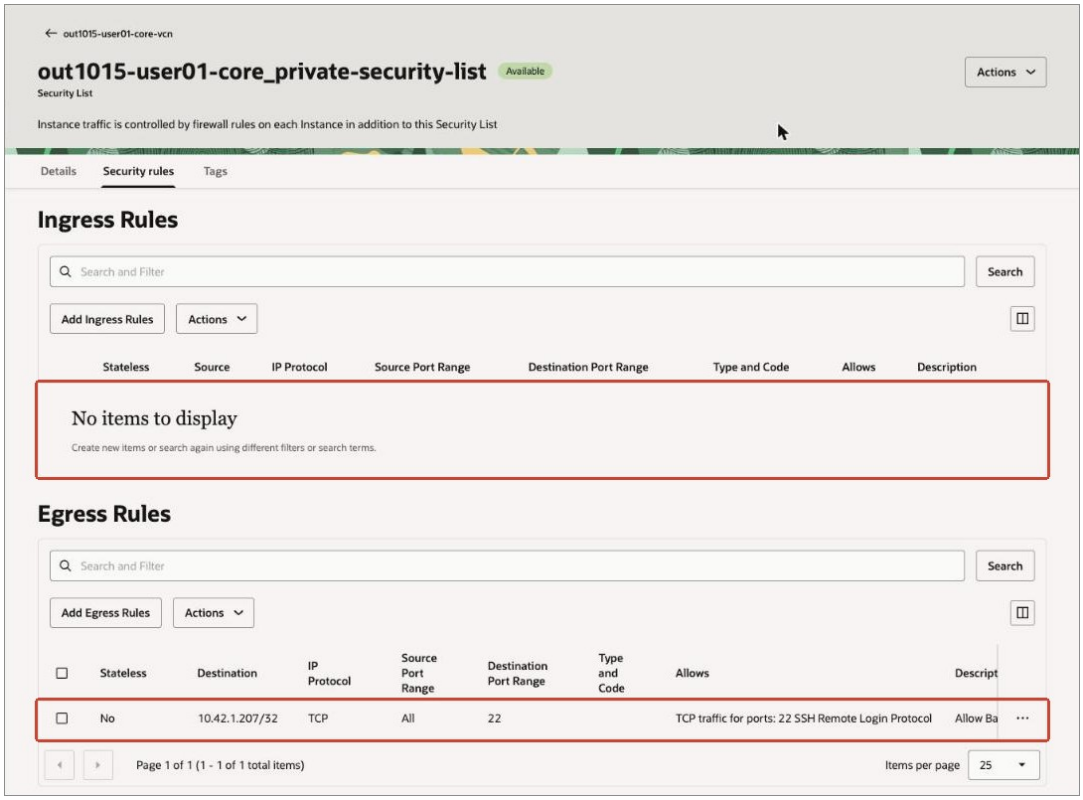


Figure 2: The private subnet's Security List: no ingress rules, and one egress rule for Bastion SSH

> **Note**
>
> Keep this page open in a browser tab. You come back to it in Practice 2-6.

Practice 2-4: Check the Application's Network Security Group

An NSG groups selected resources, wherever they sit in the VCN. A VM belongs to an NSG only if someone adds it.

1. From the navigation menu, select **Compute**, and then click **Instances**. Next to **Applied filters**, select your assigned compartment.

2. Click `out1015-userNN-app`. Click the **Networking** tab, and in the **Primary VNIC** section, find **Network security groups**. The VM belongs to `out1015-userNN-app-nsg`.

3. Click `out1015-userNN-app-nsg`, and then click the **Security rules** tab. Find the two TCP ingress rules:

Source	Port	Who it lets in
`out1015-userNN-orders_lb-nsg` (an NSG)	8080	The order load balancer, which forwards customer requests

Copyright © 2026, Oracle and/or its affiliates.

Source	Port	Who it lets in
The Bastion endpoint's IP address (`/32`)	22	Administrator SSH sessions through Bastion

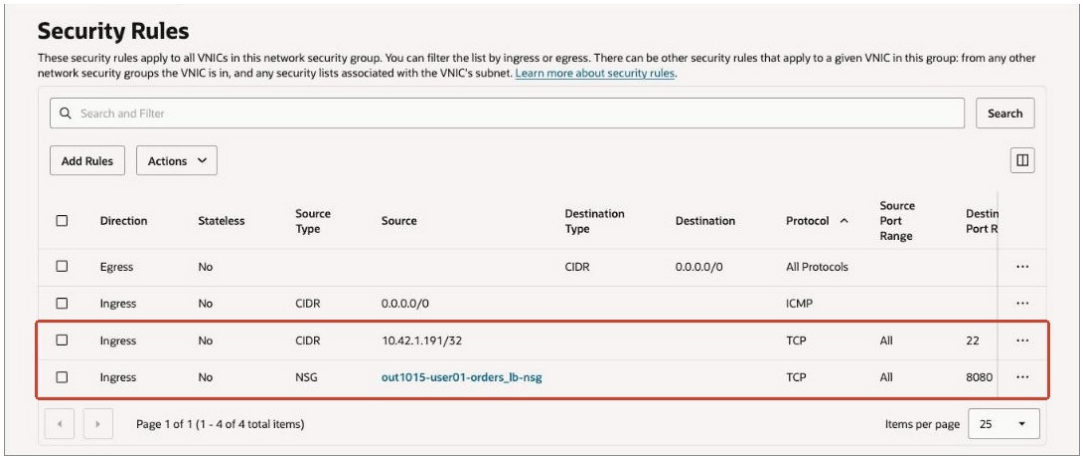


Figure 3: The application NSG admits only Bastion on port 22 and the load balancer's NSG on port 8080

> **Expected result**
>
> Only two sources may reach the application: the load balancer on the application port, and Bastion on the SSH port. No rule lets the Tools VM in.

Practice 2-5: Maintain the Application Through Bastion

Asha needs a shell on the application VM, which has no public IP address. A Bastion session gives her limited-time SSH access without opening the VM to the internet.

1. In Cloud Shell, print your public key, and copy the whole line that starts with `ssh-rsa`:

```
$ cat $KEY.pub
```

```
ssh-rsa AAAAB3NzaC1yc2E... out1015-userNN
```

2. From the navigation menu, select **Identity & Security**, and then click **Bastion**. Next to **Applied filters**, select your assigned compartment.

3. Click `out1015userNNbastion`. Click the **Sessions** tab, and then click **Create session**.

4. Enter these values, and click **Create session**:

Field	Value
Session type	**Managed SSH session**

Copyright © 2026, Oracle and/or its affiliates.

Field	Value
Session name	`out1015-userNN-admin`
Username	`opc`
Compute instance compartment	Your assigned compartment
Compute instance	`out1015-userNN-app`
Add SSH key	**Paste SSH key**, and paste the line that you copied in step 1

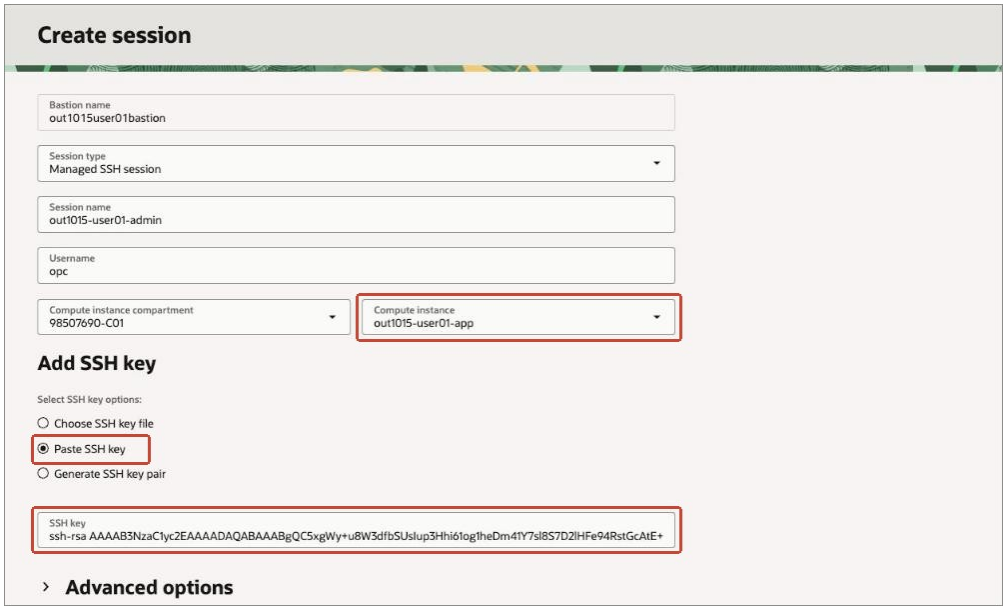


Figure 4: Create session: a managed SSH session to the order application VM, with your public key

5. Wait about a minute, until the session is **Active**. The list does not always refresh by itself: if it still shows **Creating**, open the three-dots menu of the session; **View SSH command** is available as soon as the session is Active.

6. Click the three dots next to the session, and click **View SSH command**. Click **Copy**, and then **Close**.

Copyright © 2026, Oracle and/or its affiliates.

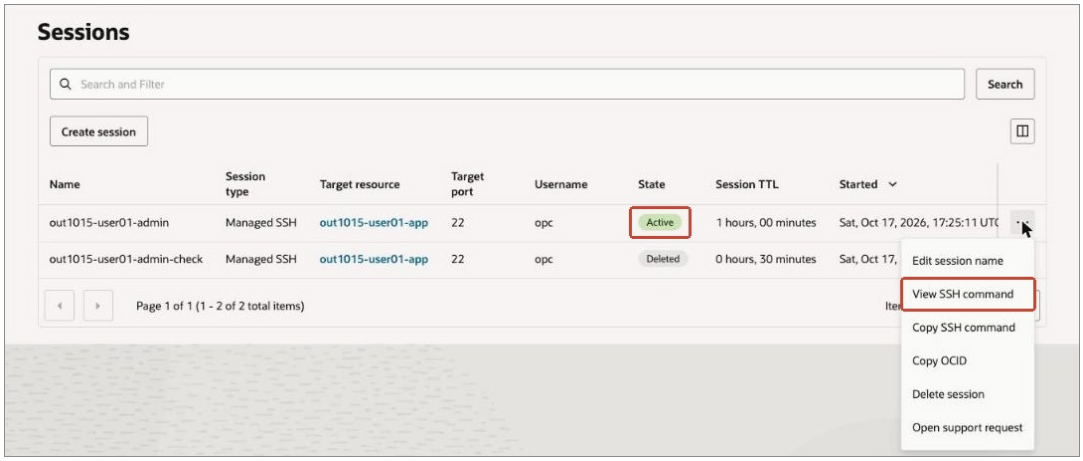


Figure 5: The session is Active. Open View SSH command from the session's menu

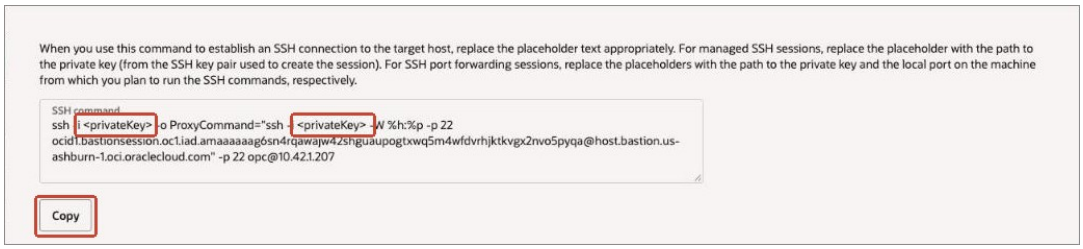


Figure 6: The SSH command. You replace both privateKey placeholders with $KEY

7. Paste the command into Cloud Shell, but do not press Enter yet. Replace both `<privateKey>` placeholders with `$KEY`. The command is one long line; here it is split over three lines to fit the page:

```
ssh -i $KEY -o ProxyCommand="ssh -i $KEY -W %h:%p -p 22
ocid1.bastionsession.oc1.iad.<id>@host.bastion.us-ashburn-1.
oci.oraclecloud.com" -p 22 opc@10.42.1.207
```

8. Press Enter. When SSH asks whether to continue connecting, type `yes`. You can be asked twice, once for Bastion and once for the VM.

9. On the application VM, check who and where you are, and whether the application is running:

```
$ hostname; whoami
$ systemctl is-active summit-order-app
$ curl -sS http://127.0.0.1:8080/healthz
$ exit
```

```
summit-app
opc
active
summit-order-app: ok
```

Copyright © 2026, Oracle and/or its affiliates.

> **Expected result**
>
> You reached the private VM as an administrator, through a session that expires on its own after at most one hour.

Practice 2-6: Reproduce the Incident

Now play the colleague. First confirm that the Tools VM cannot reach the application directly. Then add the colleague's rule and test again.

1. From Cloud Shell, ask the Tools VM to call the application directly. When SSH asks whether to continue connecting, type `yes`:

```
$ ssh -i $KEY opc@$TOOLS \
  "curl -sS --connect-timeout 5 http://$APP:8080/healthz"
```

```
curl: (28) Connection timed out after 5001 milliseconds
```

2. Return to the browser tab with `out1015-userNN-core_private-security-list` from Practice 2-3. On the **Security rules** tab, in the **Ingress Rules** section, click **Add Ingress Rules**.

3. Enter the colleague's rule, and click **Add Ingress Rules**:

Field	Value
Stateless	Do not select
Source Type	**CIDR**
Source CIDR	`10.42.0.0/16` (the whole VCN)
IP Protocol	**TCP**
Source Port Range	All
Destination Port Range	`8080`
Description	`Temporary: monitoring access`

Copyright © 2026, Oracle and/or its affiliates.

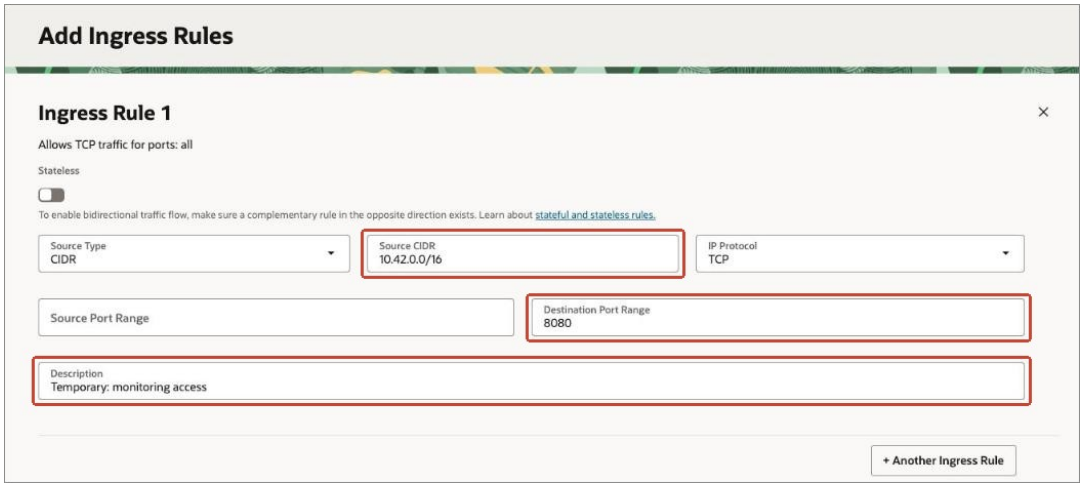


Figure 7: The colleague's broad rule: the whole VCN on port 8080

4. Wait a few seconds, and run the same direct test again:

```
$ ssh -i $KEY opc@$TOOLS \
  "curl -sS --connect-timeout 5 http://$APP:8080/healthz"
```

```
summit-order-app: ok
```

> **Expected result**
>
> The Tools VM now reaches the application directly, although the application's NSG did not change. In OCI, the allow rules of the Security List and the NSG add up: traffic that either one allows gets through.

Practice 2-7: Remove the Broad Rule

1. On the **Security rules** tab of the Security List, find the rule with the description `Temporary: monitoring access`. Click the three dots at the end of its row, and click **Remove**. Confirm when prompted.

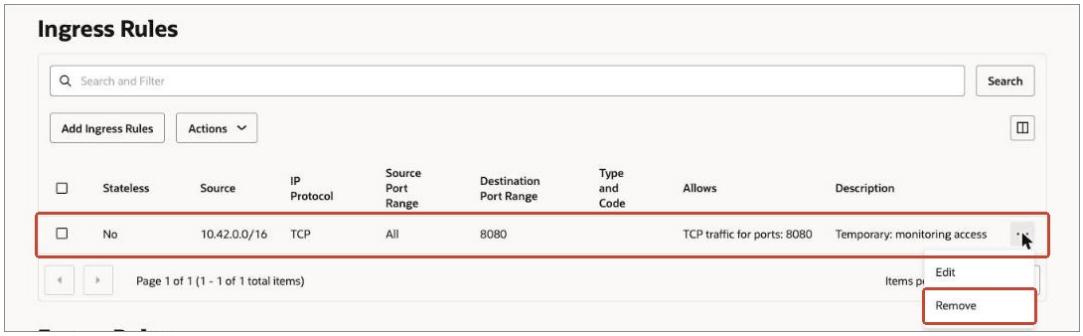


Figure 8: Remove the temporary rule from the Security List

Copyright © 2026, Oracle and/or its affiliates.

2. Check that the **Ingress Rules** section is empty again. Do not touch the egress rule on port 22; Bastion needs it.

3. Run the direct test again, and then check the customer path:

```
$ ssh -i $KEY opc@$TOOLS \
  "curl -sS --connect-timeout 5 http://$APP:8080/healthz"
$ curl -sS $ORDERS/healthz
```

```
curl: (28) Connection timed out after 5001 milliseconds
summit-order-app: ok
```

> **Expected result**
>
> The direct path is closed again, and customers still reach the application through the load balancer.

Practice 2-8: End the Administrator Session

1. In the Bastion's **Sessions** tab, click the three dots next to `out1015-userNN-admin`, and click **Delete session**. Confirm when prompted.

2. (Optional) Run the SSH command from Practice 2-5 again. The session no longer exists, so the connection is refused.

```
Permission denied (publickey).
```

Checkpoint: What You Proved

State	Tools VM directly to the app	Customers through the load balancer
Starting point	Blocked (timeout)	Works
With the colleague's rule	**Works (unintended)**	Works
After you removed it	Blocked (timeout)	Works

- Which resources does a rule in the private subnet's Security List affect?
- If you add another VM to the private subnet, does it join `out1015-userNN-app-nsg` automatically?
- The colleague needed monitoring access. What would have been a narrower rule?

Copyright © 2026, Oracle and/or its affiliates.

> **Checkpoint**
>
> **1.** Every VNIC in that subnet, including any VM added later, but nothing in other subnets.
>
> **2.** No. NSG membership is chosen for each VNIC. That is why the NSG is the right place for rules about one application.
>
> **3.** An NSG rule on `out1015-userNN-app-nsg` whose source is the Tools VM's own NSG, or its single IP address (`/32`), on port 8080 only. Better still, monitor through the load balancer's health checks.

Learn More

- Security rules (Security Lists and NSGs): https://docs.oracle.com/en-us/iaas/Content/Network/Concepts/securityrules.htm
- OCI Bastion overview: https://docs.oracle.com/en-us/iaas/Content/Bastion/Concepts/bastionoverview.htm

Copyright © 2026, Oracle and/or its affiliates.

Need Help?

Raise your hand, and an instructor will come to you. Before that, check the common problems below.

- An empty address in a command: Cloud Shell restarted and forgot the variables. Set them again as in Practice 2-1.
- The Bastion session fails or stays in **Creating**: check that you selected `out1015-userNN-app` and pasted the whole public key line. Delete the session and create a new one.
- SSH through Bastion reports `Permission denied (publickey)`: check that both `<privateKey>` placeholders now read `$KEY`, the user is `opc`, and the session is Active.
- **Create session** fails with `the Bastion plugin must be in the RUNNING state`: the application VM is still starting. In Cloud Shell, run `cd ~/out1015-lab && python3 lab.py status`, and create the session once it reports `Environment ready.`
- SSH reports `REMOTE HOST IDENTIFICATION HAS CHANGED`: your Cloud Shell remembers an older VM with the same address, for example after you rebuilt Practice 0. Run `ssh-keygen -R <address>` with the address from the message, and connect again.
- SSH through Bastion times out: check that the session is Active and the egress rule on port 22 is still in the private subnet's Security List.
- The direct test works before you add the rule: look for an extra ingress rule in the private subnet's Security List, and tell your instructor.
- The direct test still works after you removed the rule: wait a few seconds, and check that you removed the rule with the description `Temporary: monitoring access`.

Copyright © 2026, Oracle and/or its affiliates.

Clean Up

Clean up when your instructor tells you to, normally at the end of the day. The lab resources incur charges while they exist.

Check for Leftover Lab Changes

1. In your Bastion's **Sessions** tab, delete any session that is still **Active**.

2. In `out1015-userNN-core_private-security-list`, check that the **Ingress Rules** section is empty. Remove the rule `Temporary: monitoring access` if it is still there.

Copyright © 2026, Oracle and/or its affiliates.

Acknowledgements

- **Author:** Saurabh Patil, Principal OCI Instructor, Oracle University
- **Workshop:** OUT1015 Zero Trust Security with OCI, Oracle AI World 2026
- **Last updated:** October 2026

Copyright © 2026, Oracle and/or its affiliates.